
Mesa de Crisis

Plan de Respuesta ante Incidente de Ransomware con Filtración de Información

Marco **SANS PICERL** — Preparación · Identificación · Contención ·
Erradicación · Recuperación · Lecciones aprendidas

Escenario: DataMarket S.A.S.

Título	Laboratorio
Módulo	4 — Gestión de incidentes y cumplimiento normativo
Submódulo	Respuesta a incidentes de seguridad
Nombre del producto	Guía de laboratorio
Aplica a	Desktop: X Server: X
Estudiantes	Cristian Camilo Perez
Docente	Giovanny Escobar Uribe
Fecha de entrega	<i>[dd/mm/aaaa]</i>
Palabras clave	Respuesta a incidentes, SOC, SANS PICERL, Ransomware

Índice

1	Escenario del incidente	2
1.1	Situación inicial	2
1.2	Evidencia inicial disponible	2
2	Desarrollo por fases (SANS PICERL)	4
2.1	Fase 1 — Preparación	4
2.2	Fase 2 — Identificación (Detección y Análisis)	7
2.3	Fase 3 — Contención	8
2.4	Fase 4 — Erradicación	9
2.5	Fase 5 — Recuperación	10
2.6	Fase 6 — Lecciones aprendidas	10

1 Escenario del incidente

1.1 Situación inicial

La empresa **DataMarket S.A.S.** opera una plataforma web para clientes corporativos. Cuenta con ~300 empleados y una infraestructura híbrida:

- Servidores Windows para directorio activo, archivos compartidos y aplicaciones internas.
- Servidores Linux para aplicaciones web y bases de datos.
- Firewall perimetral y VPN para empleados remotos.
- SIEM con logs de firewall, Windows Server, Linux y antivirus.
- Copias de seguridad diarias de servidores críticos.
- Servicio de correo corporativo en la nube.
- Equipo de soporte TI en horario laboral. *No existe SOC interno 24/7*; el monitoreo es parcial.

Línea de tiempo del incidente:

- **7:40 a.m.** — Usuarios reportan que no pueden acceder a archivos compartidos; aparecen extensiones desconocidas y una nota de rescate.
- **8:05 a.m.** — TI identifica tres servidores Windows con alto consumo de CPU y múltiples archivos cifrados.
- **8:20 a.m.** — El SIEM muestra conexiones sospechosas desde una cuenta administrativa hacia varios servidores durante la madrugada.
- **8:45 a.m.** — Clientes reportan correos sospechosos enviados desde una cuenta corporativa.
- **9:10 a.m.** — Un grupo de ransomware publica en un foro clandestino que comprometió a DataMarket y amenaza con divulgar datos de clientes si no se paga.

1.2 Evidencia inicial disponible

El equipo deberá analizar la siguiente información (insumo del caso).

Alertas del SIEM

Hora	Fuente	Evento
02:13	VPN	Inicio de sesión exitoso desde país inusual con usuario administrativo.
02:17	Active Directory	Múltiples autenticaciones exitosas hacia servidores internos.
02:45	Windows Server	Creación de proceso sospechoso en servidor de archivos.
03:05	Firewall	Conexiones salientes hacia IP desconocida en puerto 443.
03:30	Antivirus	Detección de comportamiento tipo ransomware.
04:10	Windows Server	Alto volumen de modificación de archivos.
07:40	Mesa de ayuda	Usuarios reportan archivos inaccesibles.
08:45	Correo	Clientes reportan correos sospechosos desde cuenta corporativa.

Activos afectados conocidos

Activo	Función	Estado
FILESRV01	Servidor de archivos	Archivos cifrados
FILESRV02	Servidor de archivos	Posiblemente afectado
AD01	Controlador de dominio	Actividad sospechosa
WEBAPP01	Aplicación web de clientes	En operación
DBCLIENTES01	Base de datos de clientes	Sin evidencia confirmada de daño
VPN Gateway	Acceso remoto	Login sospechoso
Cuenta admin01	Administración de servidores	Posible compromiso
Cuenta comercial05	Correo corporativo	Posible abuso para phishing

2 Desarrollo por fases (SANS PICERL)

2.1 Fase 1 — Preparación

Como preparación necesaria para la respuesta a incidentes y debido a restricciones de personal, se definen los siguientes roles :

Rol	Responsabilidad principal	Asignado a
Incident Manager	Coordina la respuesta, toma decisiones y prioriza acciones.	Cristian Perez
Analista de seguridad	Revisa alertas, eventos, indicadores y evidencia inicial.	Cristian Perez
Soporte de TI	Apoya acciones sobre servidores, red, backups y accesos.	Cristian Perez
Analista forense	Define evidencia a preservar y posibles fuentes de investigación.	Cristian Perez
Comunicaciones / Legal	Define mensajes, notificaciones, riesgos legales y escalamiento.	Cristian Perez
Relator	Documenta decisiones, línea de tiempo y entregables del equipo.	Cristian Perez

Además se determinaron los siguientes **contactos clave** a activar durante la crisis:

Contacto	Cargo / entidad	Teléfono / correo
Gerencia / Dirección general	Autoriza decisiones y el pago del rescate	gerencia@datamarket.it +57 320 415 7782
Coordinador / Jefe de TI	Lidera las acciones técnicas de respuesta	coordinacionit@datamarket.it +57 311 268 0934
Asesor legal / jurídico	Riesgos legales y notificaciones obligatorias	sopjuridico@lawyersas.com +57 601 486 2200
Soporte correo en la nube	Bloqueo de cuentas comprometidas y phishing	soporte365@cloudmail.com 01 8000 519 042
Firma externa de respuesta / forense (DFIR)	Apoyo experto e investigación	respuesta@dfircol.com +57 601 755 3380
Aseguradora de ciberriesgo	Cobertura, guía y proveedores avalados	siniestros@segurosiber.com 01 8000 423 118
Superintendencia de Industria y Comercio (SIC)	Notificación por fuga de datos personales	contactenos@sic.gov.co +57 601 587 0000
CAI Virtual – Policía Nacional / Fiscalía	Denuncia por extorsión y delito informático	caivirtual@policia.gov.co Línea 165

Completa el teléfono/correo real de cada contacto. Confirma con tu docente los canales vigentes de las autoridades (SIC, Policía, colCERT).

Y los siguientes **elementos de preparación**, con su definición:

Herramientas requeridas. Firewall, SIEM (Implementado), EDR, Sistema de backups (implementado parcialmente), IDS/IPS, DLP, SOAR, Inteligencia de amenazas, gestión de casos (no implementado),

Fuentes de logs. Firewall, AD, VPN, SysLogs, Logs de autenticación (implementado), EDR, IPS/IDS, MFA, PAM, proxy, Logs de la aplicación web (WEBAPP01) y de la base de datos (DBCLIENTES01) (no implementados)

Backups necesarios. Seguir en la medida de lo posible la regla 3-2-1: 3 copias de los datos, 2 medios diferentes, 1 copia fuera del sitio. Se recomienda que los backups sean inmutables y que se realicen pruebas periódicas de restauración.

Criterios de severidad. Se definieron los siguientes criterios de severidad:

Severidad	Criterio
Baja	Evento limitado, sin impacto operativo ni datos sensibles comprometidos.
Media	Afectación controlada de uno o pocos activos, sin impacto crítico al negocio.
Alta	Afectación de servicios importantes, cuentas privilegiadas o datos sensibles.
Crítica	Interrupción significativa del negocio, ransomware activo, fuga de datos o impacto reputacional/legal relevante.

Procedimientos de escalamiento. 1. Analista de seguridad escala al incident manager, pues las alertas del SIEM indican actividad inusual crítica que requiere análisis más profundo.

2. El incident manager escala coordina la respuesta de los otros roles .
3. El equipo de soporte de TI encuentra evidencia de cifrado de archivos y reporta al incident manager.
4. El incident manager decide activar al equipo de comunicaciones y legal para preparar mensajes a clientes y autoridades.
5. El incident manager escala al gerente de la empresa para informar sobre la situación y obtener autorización para acciones críticas, incluyendo la posible negociación con los atacantes.
6. El analista forense recopila evidencia y reporta hallazgos al incident manager, quien decide si se requiere apoyo externo de expertos en respuesta a incidentes.
7. El incident manager escala a la aseguradora de ciberriesgo para coordinar cobertura y apoyo adicional.
8. El relator documenta todas las acciones y decisiones, y reporta al incident manager para mantener un registro completo del incidente, y este a su vez reporta a la gerencia.
9. La gerencia decide si se requiere notificación a la Superintendencia de Industria y Comercio (SIC) y a la Policía Nacional / Fiscalía, siguiendo los protocolos legales y regulatorios.

Canales de comunicación durante la crisis.

Canales de comunicación durante la crisis. Toda la comunicación se gestiona de forma **controlada** (un único vocero, need-to-know, sin filtraciones ni desinformación) y por **canales fuera de banda**, ya que el correo corporativo está comprometido:

- **Equipo de respuesta (interno):** grupo seguro en WhatsApp, más una sala de crisis (war room) coordinada por el Incident Manager.
- **Dirección/Gerencia:** reportes del Incident Manager por el canal seguro definido.
- **Empleados:** comunicado interno por canal alterno, con instrucciones (no abrir correos sospechosos, reportar a la mesa de ayuda).
- **Clientes:** un único mensaje oficial validado por Comunicaciones/Legal, por un canal confiable (no desde la cuenta comprometida), advirtiendo del phishing.
- **Autoridades:** SIC y Policía/Fiscalía, gestionadas por Legal.
- **Medios/público:** solo a través del vocero designado.

El Relator registra todas las comunicaciones y decisiones.

2.2 Fase 2 — Identificación (Detección y Análisis)

Nombre del incidente	Ataque de ransomware y exfiltración de datos
Fecha y hora de detección	26 de junio de 2026, 7:40 hrs
Tipo de incidente	Ataque de ransomware y exfiltración de datos debido a compromiso de credenciales administrativas
Activos afectados	FILESRV01, FILESRV02, AD01, WEBAPP01, DB-CLIENTES01,DBCLIENTES01,Cuenta admin01,Cuenta comercial05
Usuarios/cuentas involucradas	Usuario administrativo admin01, cuenta comercial05
Evidencia principal	Logs SIEM, archivos cifrados, nota de rescate, correos de phishing, publicación de la amenaza en foro clandestino
Impacto inicial	Critico, se presenta indisponibilidad de servicios debido al cifrado y exfiltración de datos que pueden conllevar sanciones legales y reputacionales
Alcance conocido	Cifrado confirmado en FILESRV01 y en tres servidores Windows (archivos con extensiones desconocidas y nota de rescate). Cuenta admin01 usada desde país inusual con movimiento lateral hacia servidores internos. Cuenta comercial05 usada para enviar phishing a clientes. El grupo de ransomware publicó una amenaza de divulgación de datos.
Alcance por confirmar	Compromiso real de FILESRV02 (posiblemente afectado), AD01 (actividad sospechosa) y DBCLIENTES01 (sin evidencia confirmada). Si WEBAPP01 o la base de datos de clientes fueron accedidas.
Severidad propuesta	Crítica
Justificación de la severidad	Ransomware activo (cifrado en curso), fuga de datos de clientes con amenaza pública de divulgación, compromiso de cuentas privilegiadas (admin01), interrupción significativa del negocio e impacto reputacional y legal (notificación a la SIC por datos personales).

2.3 Fase 3 — Contención

Acción	Tipo de contención	Responsable	Prioridad	Riesgo de la acción
Aislar FILESRV01 de la red	Inmediata	Soporte TI	Muy alta	Puede afectar acceso a archivos
Suspender cuenta admin01	Inmediata	Soporte TI	Muy alta	interrumpe tareas administrativas legítimas
Suspender cuenta comercial05	Inmediata	Soporte TI	Muy alta	deja sin correo al empleado legítimo
Revocar sesiones activas de cuentas comprometidas	Inmediata	Soporte TI	Alta	Puede interrumpir trabajo legítimo de usuarios
proteger backups	Inmediata	Soporte TI	Alta	Puede requerir tiempo y recursos
Informa a los clientes sobre posible phishing	corto plazo	Comunicaciones / Legal	Alta	Puede generar alarma entre clientes
Aislar FILESRV02 de la red	corto plazo	Soporte TI	media	Puede afectar acceso a archivos
Bloquear IP/dominio de salida hacia el C2 en el firewall	Corto plazo	Analista de seguridad	Media	Podría bloquear tráfico legítimo si la IP es compartida

La primera fila (en gris) es un ejemplo del enunciado.

2.4 Fase 4 — Erradicación

Elemento a erradicar	Acción	Evidencia requerida	Responsable
Credenciales comprometidas	Reset de contraseñas y revocación de sesiones	Logs de AD, VPN y correo	Soporte TI
Ransomware	Analizar equipos afectados, identificar artefactos maliciosos y eliminar estos archivos. Formateo como ultimo recurso	Logs de antivirus, EDR y SIEM	Soporte TI / Analista de seguridad
Reglas de reenvío maliciosas en comercial05	Identificar las reglas asociadas a phishing y eliminarlas	Logs de auditoría del correo en la nube, SIEM, reportes de usuarios	Soporte TI / Analista de seguridad
Métodos MFA del atacante / MFA débil	Eliminar métodos MFA no reconocidos y forzar MFA en cuentas privilegiadas	Logs de identidad (AD/Entra ID), registro de métodos MFA	Soporte TI / Analista de seguridad
Claves API potencialmente expuestas	Rotar las claves API y revisar su uso	Inventario de claves, logs de uso de API	Soporte TI
Vector de entrada VPN (configuración débil)	Cerrar la configuración débil: forzar MFA en la VPN y revisar accesos remotos	Logs de VPN, configuración del gateway	Soporte TI
Persistencia del atacante	Buscar y eliminar mecanismos de persistencia (cuentas creadas, tareas programadas, servicios, backdoors)	EDR, logs de AD, Windows y Linux	Analista de seguridad / Soporte TI
Privilegios excesivos	Revisar y reducir privilegios (p. ej. admin01) aplicando mínimo privilegio	AD, revisión de grupos y privilegios	Soporte TI / Analista de seguridad
Vulnerabilidades sin parchar	Aplicar parches a los sistemas operativos y aplicaciones afectados	Escaneo de vulnerabilidades, inventario de parches	Soporte TI
Sistemas posiblemente comprometidos	Barrido y threat hunting en todos los activos para confirmar que no quedan sistemas comprometidos	EDR, SIEM, IoC del ataque	Analista de seguridad

La primera fila (en gris) es un ejemplo del enunciado.

2.5 Fase 5 — Recuperación

Servicio / Activo	Prioridad	Método de recuperación	Validación requerida	Responsable
AD01	1	Validar integridad o reconstruir controlador afectado	Autenticación, GPO, eventos críticos	Soporte TI
DBCLIENTES01 (base de datos de clientes)	1	Restaurar desde backup limpio y validar la integridad de la base de datos	Integridad de datos, sin accesos no autorizados, escaneo EDR limpio	Soporte TI
Cuentas admin01 y comercial05	1	Rehabilitar tras reset de contraseña y nuevo registro de MFA	Acceso normal, sin reglas de reenvío ni persistencia	Soporte TI
FILESRV01 y FILESRV02 (servidores de archivos)	2	Restaurar desde backups limpios validados	Archivos accesibles, sin cifrado activo, escaneo EDR limpio	Soporte TI
Correo corporativo	2	Restablecer la operación tras limpiar reglas de buzón y validar	Sin phishing saliente, reglas de buzón limpias	Soporte TI
WEBAPP01 (aplicación web de clientes)	2	Reintegrar por fases tras validar el servicio	Funcionamiento correcto, sin conexiones salientes sospechosas	Soporte TI
VPN Gateway	2	Restablecer el acceso remoto con MFA	Accesos legítimos, sin inicios de sesión anómalos	Soporte TI
Operación general	3	Reintegrar los sistemas por fases y monitorear reinfección	SIEM/EDR sin actividad maliciosa; el negocio valida que el servicio funciona	Analista de seguridad / Soporte TI

La primera fila (en gris) es un ejemplo del enunciado.

Criterios para declarar la recuperación

No hay evidencia de cifrado activo; cuentas comprometidas bloqueadas/recuperadas; backups restaurados validados; sistemas restaurados escaneados; sin conexiones salientes sospechosas; usuarios con acceso a servicios críticos; SIEM/EDR sin actividad maliciosa persistente; el negocio valida que el servicio funciona.

2.6 Fase 6 — Lecciones aprendidas

Documenta aprendizajes, fallas del proceso y mejoras futuras. **Entregable:** matriz de lecciones aprendidas y plan de mejora.

Hallazgo	Impacto	Acción de mejora	Responsable	Prioridad
No había playbook de ransomware	Respuesta lenta y desordenada	Crear y probar playbook específico	Analista de seguridad	Alta
No hay política de contraseñas	Contraseñas débiles	Definir política de construcción de contraseñas	Analista seg. / Legal	Alta
No hay SOC ni monitoreo 24/7 (monitoreo parcial)	El ataque avanzó cerca de 6 h sin detección (las alertas de las 02:13 no se atendieron)	Implementar monitoreo 24/7 o un MSSP y automatizar alertas	Gerencia / Analista de seguridad	Alta
Faltan logs clave (sin app web, base de datos, proxy ni DLP)	Puntos ciegos en la exfiltración y el movimiento lateral	Integrar al SIEM los logs de la app web y la base de datos; implementar proxy y DLP	Analista de seguridad	Alta
Cuentas privilegiadas sin MFA	Compromiso de admin01 desde país inusual	MFA obligatorio en cuentas privilegiadas y gestión de accesos privilegiados (PAM)	Soporte TI	Alta
Backups sin inmutabilidad ni pruebas	Riesgo de cifrado de backups y recuperación incompleta	Backups offline/inmutables y pruebas periódicas de restauración (regla 3-2-1)	Soporte TI	Alta
Sin flujo de escalamiento ni canal de comunicación alterno	Confusión y retrasos en la respuesta	Definir un flujo de escalamiento con SLA y un canal fuera de banda	Incident Manager	Media
Privilegios excesivos y red sin segmentar	Movimiento lateral fácil del atacante	Aplicar mínimo privilegio y segmentación de red	Soporte TI	Media
Falta de concienciación y capacitación	Phishing exitoso desde una cuenta corporativa	Capacitación continua y simulacros periódicos	Comunicaciones / RR. HH.	Media

Las filas en gris son ejemplos del enunciado.

Fin de la plantilla — completa cada fase con tu equipo.